
<< company name >>

IT Policy

Mar 08, 2024

v0.1

Contents

1. Version History	3
2. Abbreviations, Terms and Definitions	3
3. Introduction	3
4. IT Governance	3
Strategy and Planning	3
Risk management	3
Compliance	3
Performance measurement	3
Communication	4
Continual improvement	4
5. IS Policy	4
Identification and Classification of Information Assets	4
Segregation of Duties (SoD)	4
Role Based Access Control	5
Personnel Security	5
Acceptable Use	5
Physical Security	6
Audit Trails	7
Certificate Management	7
Cyber-security Measures	7
Cyber-security Awareness	7
Cyber Crisis Management Plan and Incident Management	8
Incident Response Team	8
Incident Reporting	8
Incident Response Process	8
Communication	8
Risk Assessment	9
Social Media Risks	9
6. IT Operations	9
IT Steering Committee	9
Enterprise Architecture	9
Software Development	10
Change Management	11
Data Management	12
Helpdesk Support	12
Cloud Infrastructure	13
Asset Management	14
IT Procurement	15
7. IS Audit	16
8. Business Continuity Planning (BCP) and Disaster Recovery (DR)	17
9. IT Outsourcing	18

1. Version History

Author(s)	Date	Version	Description
		0.1	Draft

2. Abbreviations, Terms and Definitions

--	--

3. Introduction

This document outlines the IT Policy of << >>. IT Head is responsible for operationalizing this policy and enhancing it from time to time.

4. IT Governance

An IT Strategy Committee should be established, comprising members from the senior management team and IT department chaired by an Independent Director. The committee should make strategic IT decisions and ensure the IT department is aligned with the overall business strategy.

The IT governance committee should implement the following activities.

Strategy and planning

Develop a strategic plan for IT that aligns with the overall business strategy. Create an annual budget and IT project plan.

Risk management

Conduct regular risk assessments to identify potential threats to the company's IT systems and data. Mitigation plans should be developed to minimize the impact of identified risks.

Compliance

Ensure that the company's IT systems and processes are compliant with relevant laws and regulations applicable to various client businesses.

Performance measurement

Establish key performance indicators (KPIs) to measure the performance of IT systems, processes & personnel. Regular performance reviews should be conducted to identify areas for improvement.

Communication

Establish regular communication channels with other departments and stakeholders to ensure that IT initiatives are aligned with business needs.

Continual improvement

Conducts regular reviews of IT systems, processes & personnel to identify areas for improvement. Continual improvement initiatives are implemented to improve the overall effectiveness of the company's IT initiatives.

5. IS Policy

This Information Security (IS) Policy outlines the principles and procedures for protecting information assets. It aims to:

- Ensure the confidentiality, integrity, and availability of critical information.
- Minimize risks associated with data breaches, unauthorized access, and cyberattacks.
- Comply with relevant data security regulations and industry standards.

This policy applies to all employees, contractors, and any authorized users of Kanagadurga Finance information systems and data. This includes:

- Electronic data (emails, documents, databases, etc.)
- Physical data (paper files, storage devices, etc.)
- Company-owned devices (laptops, desktops, mobile phones)
- Personal devices used to access company data or systems (BYOD - Bring Your Own Device)

Identification and Classification of Information Assets

Data at << >> will be classified into three categories based on its sensitivity:

- Confidential: This includes information whose unauthorized disclosure could cause severe financial or reputational harm. Examples: trade secrets, financial data, intellectual property, employee medical records.
- Internal: This includes information that is not publicly releasable but is important for internal operations. Examples: marketing plans, customer lists, employee performance reviews.
- Public: This includes information that can be shared with the public without any risk. Examples: press releases, company website content, product brochures.

All employees are responsible for classifying data according to the definitions above. When unsure of the classification level, employees should err on the side of caution and classify the data as confidential or internal. Data classification labels will be applied to all documents and files electronically and physically.

Segregation of Duties (SoD)

Implement SoD by creating a system of checks and balances within the application workflows eg, separating tasks like initiating a transaction, approving it, and reconciling accounts across multiple users. It helps reduce the risk of fraud, prevents accidental errors and limits insider threats

Role Based Access Control

- A defined set of roles should be established, each with a clear description of its responsibilities and associated access permissions.
- Permissions should be mapped to roles based on the principle of least privilege. Users should only be granted the access they need to perform their job duties.
- Users should be assigned roles based on their job function and department.
- Access permissions should be automatically granted or revoked based on a user's assigned role(s).
- The IT department should be responsible for managing user accounts and access privileges.
- User access should be reviewed periodically to ensure continued validity and adherence to the principle of least privilege.
- This may involve reviewing role assignments and user activity logs.
- Employees are responsible for notifying IT of any changes in their job duties that may impact their access needs.
- A strong password policy should be enforced to protect user accounts from unauthorized access. This includes requiring minimum password length, complexity, and regular password changes. Multi-factor authentication (MFA) may be required for access to sensitive data or systems.
- Management is responsible for approving user access requests and enforcing this policy.
- The IT department is responsible for implementing and maintaining the RBAC system.
- Users are responsible for using their access privileges responsibly and reporting any suspicious activity.

Personnel Security

- Background checks to be conducted on new hires and existing personnel with access to sensitive information. The level of screening will be commensurate with the risk associated with the position.
- Pre-employment screening may include verifying education and employment history, criminal background checks, and reference checks.
- All employees should receive regular training on information security best practices. Training will cover topics such as password security, phishing scams, social engineering attacks, data classification, and acceptable use of IT resources.
- Upon termination of employment or contract, all access privileges to company systems and data will be revoked immediately.
- Returned company property, including laptops, mobile devices, and access cards, will be wiped clean of all data before being returned or disposed of securely.
- User activity on company systems may be monitored to detect suspicious activity and potential security breaches.
- Regular audits should be conducted to assess the effectiveness of the personnel security program.

Acceptable Use

- Employees can use email for business communication, access company-approved applications, and browse the internet for work-related information.

- The following activities are strictly prohibited:
 - Downloading or installing unauthorized software, including games or music software.
 - Accessing or distributing illegal content, including pornography, gambling websites, or copyrighted material.
 - Engaging in activities that could harm the network or systems, such as hacking attempts or spreading viruses.
 - Using company resources for personal gain, such as running a business or soliciting sales.
 - Sending harassing, discriminatory, or offensive emails or messages.
 - Sharing passwords or other confidential information.
 - Using company resources for excessive personal use, such as social media or online gaming during work hours.
- Users are responsible for creating and maintaining strong passwords for all company accounts.
- Passwords should be at least 8 characters long and include a combination of uppercase and lowercase letters, numbers, and symbols.
- Sharing passwords with anyone is strictly prohibited.
- All email communication should be professional and courteous.
- Users should avoid sending spam or unsolicited emails.
- When browsing the internet, users should avoid accessing inappropriate websites or downloading risky content.
- Users should be mindful of copyright restrictions when downloading or sharing content.
- Users are responsible for protecting sensitive company data.
- Users should not share confidential information with unauthorized individuals.
- Users should report any suspected data breaches or security incidents immediately.
- Users should be cautious about opening attachments or clicking on links in emails, especially from unknown senders.
- Employees should be encouraged to report any suspected violations of this policy to their supervisor, the IT department, or through an anonymous reporting mechanism.

Physical Security

- Building security
 - Fences, gates, or other barriers should be used to secure the perimeter of the property
 - Entry points should be controlled through security personnel, keycard access systems, or other access control measures.
 - Visitors should be required to register and sign in upon arrival and may be issued visitor badges
 - Security cameras may be installed in strategic locations to monitor activity and deter crime.
 - Intrusion detection and alarm systems may be installed to alert security personnel of unauthorized access attempts.
 - Regular maintenance of locks, doors, windows, and security systems will be performed to ensure proper functionality.
 - Employees should maintain clean desks by storing confidential documents and equipment securely when not in use
 - Visitor access to sensitive areas or data will be restricted.
- Asset security
 - A comprehensive inventory of all company assets, including equipment, data storage devices, and sensitive documents, should be maintained.
 - Company property may be marked or tagged for identification and tracking purposes.

- Secure disposal procedures will be established for electronic waste and other sensitive materials
- Controls should be placed on the use of removable media (USB drives, external hard drives) to prevent unauthorized data transfer.

Audit Trails

- Audit log should contain User ID, timestamp, action performed, accessed resource, and originating IP address
- Retention period as per RBI guidelines
- Only authorized IT security personnel should have access to view and analyze audit trail data.
- Regular reports should be generated that summarize user activity and identify any suspicious patterns.

Certificate Management

- Ensure secure and proper lifecycle management of digital certificates
- Secure key generation practices should be followed, and private keys should be stored securely by users or within approved hardware security modules (HSMs)
- Strong cryptographic algorithms should be used for certificate generation and digital signatures
- Certificates should have a limited validity period. Renewal procedures should be initiated before certificate expiration to avoid disruption
- Conduct regular audits and reviews

Cyber-security Measures

- Ensure up-to-date anti-virus / anti-malware protection on servers and endpoints
- Firewalls and intrusion detection/prevention systems (IDS/IPS) will be deployed to monitor and filter network traffic for malicious activity
- Systems and applications will be kept up-to-date with the latest security patches to address vulnerabilities
- Secure wireless networks will be implemented with strong encryption protocols (WPA2 or WPA3)
- Remote access to company systems will be restricted and controlled through secure methods (e.g., VPN)
- Regular security audits and penetration testing should be conducted to identify vulnerabilities in systems and applications
- Risk assessments should be performed to evaluate potential threats and prioritize security controls
- Implement Network Operations Centre (NOC) and Security Operations Centre (SOC) to monitor and avoid threats
- Tune into RBI / CERTIN advisory and take proactive measures

Cyber-security Awareness

- Security Training Programs: Regular training sessions educate employees, senior management and board on cyber threats, best practices, and reporting procedures.
- Awareness Campaigns: Regular reminders and educational materials can keep cybersecurity top-of-mind for employees.
- Phishing Simulations: Simulated phishing attacks can test employees' awareness and identify areas for improvement.

Cyber Crisis Management Plan and Incident Management

It should cover all types of security incidents, including:

- Data breaches (unauthorized access or disclosure of sensitive data).
- Malware infections (viruses, worms, ransomware)
- System outages and disruptions
- Denial-of-service attacks
- Phishing attempts and social engineering attacks
- Physical security incidents (unauthorized access to facilities or equipment)

Incident Response Team

An Incident Response Team (IRT) should be established, consisting of qualified personnel from IT security, operations, and other relevant departments. The IRT will be responsible for:

- Overseeing the incident response process.
- Conducting investigations into security incidents.
- Implementing containment and eradication measures.
- Coordinating communication and recovery efforts.
- Learning from incidents and improving security defenses.

Incident Reporting

- All employees should be encouraged to report any suspected security incidents, regardless of severity.
- Reporting channels should be clearly defined, such as a dedicated email address, phone hotline, or online reporting form.
- Incident reports should include details such as the nature of the incident, date and time, and any potential impact.

Incident Response Process

The incident response process should follow a defined structure, typically consisting of the following stages:

- Identification: Recognizing and identifying a potential security incident.
- Containment: Taking steps to isolate the incident and prevent further damage.
- Eradication: Removing the root cause of the incident, such as malware or unauthorized access.
- Recovery: Restoring affected systems and data to a functional state.
- Lessons Learned: Analyzing the incident to identify weaknesses and improve future defenses.

Communication

- The IRT will be responsible for coordinating communication throughout the incident response process.

- Relevant stakeholders will be informed of the incident in a timely manner, based on the severity and potential impact.
- Communication should be clear, concise, and accurate, while avoiding unnecessary technical jargon.

Risk Assessment

Improve the organization's overall security posture using the following steps

- Preparation: Define the scope of the assessment, identify critical assets, and assemble a qualified team.
- Threat Identification: Brainstorm potential threats based on industry trends, common attack vectors (phishing, malware), and internal vulnerabilities.
- Vulnerability Assessment: Use security tools and manual testing to identify weaknesses in systems, networks, and configurations.
- Risk Analysis: Evaluate the likelihood of each threat occurring and the potential impact on the organization (financial loss, reputational damage, downtime). Techniques like qualitative (high, medium, low) or quantitative (dollar value) approaches can be used.
- Control Assessment: Evaluate the effectiveness of existing security controls in mitigating identified risks. This may involve access controls, firewalls, intrusion detection systems, data encryption, etc.
- Reporting and Recommendations: Document the findings of the assessment, including identified risks, their likelihood and impact, and recommendations for control improvements or mitigation strategies.

Social Media Risks

- Educate employees about social media security best practices.
- Monitor social media for potential threats and brand mentions.
- Develop clear procedures for handling data breaches or security incidents involving social media.
- Establish guidelines for appropriate social media use during work hours.
- Consider using social media monitoring tools to identify potential risks related to recruitment or brand reputation.

6. IT Operations

IT Steering Committee

- Set up a steering committee consisting of business owners, the development team and other stakeholders to provide oversight and monitoring of the progress of the project

Enterprise Architecture

- Establish guidelines for the design, development, and maintenance of the organization's enterprise architecture. This policy applies to all IT systems, applications, and infrastructure that support the organization's mission, goals, and objectives.
- The enterprise architect is responsible for the overall design and management of the organization's enterprise architecture.
- Department heads and project managers are responsible for ensuring that new systems, applications, and infrastructure adhere to the organization's enterprise architecture.

- IT staff are responsible for implementing and maintaining systems, applications, and infrastructure that align with the organization's enterprise architecture.
- All systems, applications, and infrastructure must adhere to industry standards and best practices for security, performance, scalability, and interoperability.
- The IT Steering Committee will govern the enterprise architecture. The committee will approve changes to the enterprise architecture and ensure compliance with this policy.
- The organization will use a recognized architecture framework, such as TOGAF or Zachman, to guide the development and maintenance of the enterprise architecture.
- The enterprise architect must review and approve all new systems, applications, and infrastructure before they are implemented.
- The enterprise architecture should be documented and maintained in a central repository that is accessible to all relevant parties.
- Compliance with this policy will be regularly monitored and reported to the governance committee.
- Changes to the enterprise architecture must be proposed, reviewed, and approved by the IT Strategy Committee before they are implemented.

Software Development

All software development projects should be managed and executed in a consistent and efficient manner, meeting the needs of the organization and its customers. The organization should use an industry-standard software development framework like Agile or Waterfall to manage and monitor software development projects. The framework should be used to govern the following aspects of software development:

Project management

- Software development projects should be managed using a project management process, such as Scrum or Kanban, as per the selected framework.
- Projects should be tracked and reported on using a project management tool.

Requirements gathering

- Requirements for software development projects should be gathered through a structured process, such as user stories or use cases.
- Requirements should be reviewed and approved by stakeholders before development begins.

Design

- The design of software development projects should be based on industry best practices, such as user-centered design or object-oriented design.
- Design should be reviewed and approved by stakeholders before development begins.

Development

- Software development should be done using industry-standard programming languages and frameworks, such as C# or Python.
- Development should be reviewed and approved by stakeholders before testing begins.

Testing

- Software development projects should be tested using industry-standard testing methods, such as unit testing or acceptance testing.
- Testing should be reviewed and approved by stakeholders before deployment.

Deployment

- Software development projects should be deployed using industry-standard deployment methods, such as continuous integration and continuous delivery.

- Deployment should be reviewed and approved by stakeholders before release.

Maintenance

- Software development projects should be maintained using industry-standard maintenance methods like bug tracking and version control.
- Maintenance should be reviewed and approved by stakeholders before release.

Change Management

Ensure that all changes to the IT environment are managed in a controlled and consistent manner in order to minimize risk and ensure continuity of service. This policy applies to all changes to the IT environment, including but not limited to:

- Hardware changes (e.g. installation of new servers, upgrades to existing servers)
- Software changes (e.g. installation of new applications, upgrades to existing applications)
 - Network changes (e.g. addition of new network devices, reconfiguration of existing network devices)
 - Security changes (e.g. implementation of new security controls, changes to existing security controls)

Responsibilities:

- The change management function is the responsibility of the IT Change Manager, who will be responsible for the following tasks:
 - Reviewing and approving all change requests
 - Scheduling and coordinating all changes
 - Ensuring that all changes are properly tested and documented
 - Communicating all changes to relevant parties
 - Monitoring the status of all changes and providing regular reports to management
- All employees are responsible for:
 - Submitting change requests through the proper channels
 - Following the change management process for all changes
 - Communicating any issues or problems related to changes to the IT Change Manager

Change Request Process:

- All change requests must be submitted through the proper channels and be reviewed and approved by the IT Change Manager before being implemented.
- Change requests must include detailed information about the change, including the purpose, scope, and expected impact.

Change Scheduling and Coordination:

- All changes must be scheduled and coordinated with the IT Change Manager in order to minimize disruption to the IT environment.
- Changes should be scheduled during non-business hours whenever possible.

Change Testing and Documentation:

- All changes must be thoroughly tested before being implemented, in order to minimize the risk of problems.
- Detailed documentation of all changes must be maintained and provided to the IT Change Manager.

Change Communication:

- All changes must be communicated to relevant parties, including the IT Change Manager, IT staff, and business users.

- Communication should include information about the change, the schedule, and the expected impact.

Change Monitoring and Reporting:

- The IT Change Manager will monitor the status of all changes and provide regular reports to management on the status of changes.
- Any issues or problems related to changes must be reported to the IT Change Manager immediately.

Data Management

Ensure the confidentiality, integrity, and availability of all company data by establishing standards and procedures for the collection, storage, use, and disposal of data. This policy applies to all data owned or controlled by the company, including but not limited to:

- o Customer data
- o Financial data
- o Employee data
- o Business data
- o Sensitive data (e.g. personal information, confidential business information)

Responsibilities:

- The Data Management function is the responsibility of the Data Manager, who will be responsible for the following tasks:
 - o Reviewing and approving all data management procedures
 - o Ensuring compliance with data protection laws and regulations
 - o Managing data backups and disaster recovery procedures
 - o Providing guidance and training on data management procedures
- All employees are responsible for:
 - o Adhering to the data management procedures
 - o Keeping data confidential and secure
 - o Reporting any data breaches or incidents to the Data Manager

Data Collection:

- Data collection must be done in accordance with applicable laws and regulations.
- Data collected must be relevant and necessary for the purposes it will be used for.

Data Storage:

- Data must be stored securely, using encryption and access controls where necessary.
- Data must be backed up regularly and stored off-site in case of disaster.
- Data must be disposed of securely when it is no longer needed.

Data Use:

- Data may only be used for the purposes it was collected for, and employees must not share data with unauthorized parties.
- Data may only be accessed by employees who have a need-to-know.

Data Breaches:

- In the event of a data breach, the Data Manager must be notified immediately, and appropriate action must be taken to mitigate the breach and prevent further damage.

Helpdesk Support

All helpdesk support requests should be handled promptly, efficiently, and professionally, meeting the needs of the organization and its customers or employees. This policy applies to all helpdesk support requests, including but not limited to:

- Technical issues
- Software support
- Hardware support
- Network support
- Security support

Service Level Agreement (SLA):

- The organization should have a Service Level Agreement (SLA) in place for helpdesk support, outlining the expected response and resolution times for different types of requests.
- SLA should be communicated to customers or employees.

Support Request Process:

- Helpdesk support requests should be submitted through a designated channel, such as email, phone, or web form.
- Requests should be logged in a ticketing system and assigned to the appropriate team member.
- Requests should be tracked and reported on using the ticketing system.

Prioritization:

- Helpdesk support requests should be prioritized based on their urgency and impact on the organization's operations.
- High-priority requests should be addressed immediately, while lower-priority requests will be handled as soon as possible.

Escalation:

- If the initial team member cannot resolve a help desk support request, it should be escalated to a higher-level team member or manager for further assistance.

Communication:

- Customers or employees should be kept informed of the status of their helpdesk support request through regular updates.
- If a request is expected to take an extended period of time to resolve, the customer or employee should be informed of the expected resolution date.

Resolution:

- Helpdesk support requests should be resolved as soon as possible, according to the SLA.
- A workaround or alternative solution should be provided if a request cannot be resolved.

Follow-up:

- After a help desk support request is resolved, a follow-up should be made to the customer or employee to ensure that the problem is resolved to their satisfaction.

Cloud Infrastructure

Ensure the secure and compliant use of cloud computing services within the company. This policy applies to all employees, contractors, and third parties who use cloud computing services on behalf of the company.

Responsibilities:

- The IT department is responsible for:
 - o Reviewing and approving all cloud computing services used by the company

- Ensuring that all cloud computing services are in compliance with company policies and procedures
 - Managing vendor relationships
- All employees are responsible for:
 - Adhering to the policy when using cloud computing services
 - Reporting any violations of the policy to the IT department

Service Approval:

- All cloud computing services used by the company must be reviewed and approved by the IT department.
- Approval will be based on the service's compliance with company policies and procedures, as well as relevant laws and regulations.

Vendor Selection:

- The IT department will review and approve all vendor selection for cloud computing services.
- Vendors must meet the following criteria:
 - Compliance with relevant laws and regulations
 - Ability to meet the company's technical and security requirements
 - Competitive pricing
 - Good reputation and references

Data Management:

- All data stored in cloud computing services must be protected in accordance with company data management policies and procedures.
- All data must be encrypted in transit and at rest.

Incident Management:

- The IT department must be informed of any incident or data breaches that occurs in the cloud computing services.
- The IT department will investigate and take appropriate action to remediate the incident, in accordance with the incident management policy.

Asset Management

Ensure that all company IT assets are managed in an efficient and effective manner in order to maximize their value, minimize risk, and ensure compliance. This policy applies to all IT assets, including but not limited to:

- Hardware (e.g. computers, servers, printers)
- Software (e.g. operating systems, applications, licenses)
- Mobile devices (e.g. smartphones, tablets)
- Network equipment (e.g. routers, switches)

Responsibilities:

- The IT asset management function is the responsibility of the IT Asset Manager, who will be responsible for the following tasks:
 - Maintaining an accurate inventory of all IT assets
 - Tracking the acquisition, deployment, maintenance, and disposition of IT assets
 - Ensuring compliance with software licensing agreements
 - Managing the lifecycle of IT assets, including replacement and disposal
 - Providing regular reports on the status of IT assets to management
- All employees are responsible for:
 - Properly using, maintaining, and securing IT assets in their possession

- Reporting lost, stolen, or damaged IT assets to the IT Asset Manager immediately

IT Asset Maintenance and Repairs:

- Regular maintenance and repairs must be performed on all IT assets in order to ensure their proper functioning and longevity.
- The IT Asset Manager must approve any repairs or maintenance, and a record of the work must be kept in the IT asset management system.

IT Asset Disposal:

- All IT assets must be disposed of in accordance with local, state, and federal laws, as well as company policies.
- The IT Asset Manager must be notified before any IT assets are disposed of, and must approve the disposal before it takes place.

IT Asset Security:

- All IT assets must be secured when not in use, and must be protected against theft, damage, and unauthorized access.
- All employees must immediately report any security issues or incidents involving IT assets to the IT Asset Manager.

Software Licensing Compliance:

- All software must be licensed and used in accordance with the terms of the license agreement.
- The IT Asset Manager will ensure compliance with all software licensing agreements and will work with legal counsel as needed to resolve any compliance issues.

IT Procurement

Ensure that all IT purchases are made in compliance with company policies and procedures, as well as applicable laws and regulations. This policy applies to all IT purchases made by the company, including but not limited to:

- Hardware (e.g. computers, servers, printers)
- Software (e.g. operating systems, applications)
- Services (e.g. consulting, support)

Responsibilities:

- The IT department is responsible for:
 - Reviewing and approving all IT purchase requests
 - Ensuring that all IT purchases are in compliance with company policies and procedures
 - Managing vendor relationships
- All employees are responsible for:
 - Submitting IT purchase requests in accordance with the policy
 - Adhering to the policy when making IT purchases

IT Purchase Requests:

- All IT purchase requests must be submitted to the IT department for review and approval.
- Purchase requests must include the following information:
 - Description of the item or service being requested
 - Budget and cost estimates
 - Justification for the purchase
 - Approval from the relevant department or manager

Vendor Selection:

- The IT department should review and approve all vendor selection.
- Vendors must meet the following criteria:
 - Compliance with relevant laws and regulations

- Ability to meet the company's technical and security requirements
- Competitive pricing
- Good reputation and references

Contract Management:

- All IT purchase contracts must be reviewed and approved by the IT department and Legal department.
- Contracts must include clauses for warranties, service level agreements, and termination provisions.

7. IS Audit

- IS Audit should be conducted atleast once a year.
- Risk-based audits should be conducted more frequently, focusing on areas identified as high-risk through
 - Ongoing security monitoring activities.
 - Security incidents or near misses.
 - Implementation of new IT systems or applications.
 - Changes in the regulatory landscape.
- A standardized and documented methodology should be employed for all IS audits, ensuring consistency and effectiveness. The methodology should typically consist of the following stages:
 - Planning and Scoping: Define the audit objectives, scope, and timeframe based on RBI requirements, risk assessments, and management priorities.
 - Data Collection and Analysis: Gather information through interviews with key personnel, document reviews, testing of controls aligned with the RBI IT Master Direction, and analysis of security logs and system activity.
 - Reporting: Prepare comprehensive IS audit reports outlining the findings, identified risks and control deficiencies, recommendations for improvement, and timelines for remediation, considering reporting requirements mandated by RBI.
 - Remediation: Develop and implement a plan to address identified control deficiencies and vulnerabilities based on the audit report.
- Management should
 - Provide necessary resources for conducting IS audits.
 - Ensure timely remediation of control deficiencies identified during audits.
 - Maintain oversight of the overall IS audit process.
- Internal Audit Team (or Appointed Auditor) should
 - Conduct or oversee IS audits in accordance with professional auditing standards and maintain independence and objectivity as per RBI guidelines.
 - Communicate IS audit findings and recommendations to management.
- Business Unit Owners should
 - Responsible for the security and compliance of IT systems within their respective business units.
 - Implement corrective actions based on IS audit recommendations.
- Communication and Reporting: IS audit reports should be communicated to relevant stakeholders, including
 - Board of Directors or Audit Committee (as mandated by RBI)
 - Management Team

- IT Security Team
- Business Unit Owners

The reports should clearly articulate the audit findings, identified risks, and recommendations for improvement.

- IS Audit Policy should be reviewed and updated periodically to reflect:
 - Changes in technology and evolving threats.
 - Updates to the RBI IT Master Direction and other relevant regulations.
 - Findings and recommendations from previous IS audits.
- All information obtained during IS audits will be treated as confidential and used solely for the purposes of improving IT security, compliance, and meeting RBI reporting requirements.

8. Business Continuity Planning (BCP) and Disaster Recovery (DR)

- The primary objectives of this BCP/DR Plan are to:
 - Minimize downtime and ensure the timely resumption of critical business functions following a disaster.
 - Protect the confidentiality, integrity, and availability of the NBFC's information assets.
 - Mitigate the financial and reputational risks associated with business disruptions.
 - Maintain customer service and trust during disruptive events.
 - Ensure compliance with the RBI IT Master Direction's BCP/DR requirements for NBFCs.
- A comprehensive BIA has to be conducted to identify critical business functions (CBFs) essential for the NBFC's operation. The BIA determines the Maximum Tolerable Downtime (MTD) for each CBF, which is the acceptable period of disruption before unacceptable financial or reputational loss occurs.
- A risk assessment has to be conducted to identify potential threats and vulnerabilities that could disrupt IT systems and operations. This includes consideration of natural disasters, cyberattacks, power outages, hardware failures, and other potential events.
- Based on the BIA and risk assessment, recovery strategies has to be defined for critical business functions. These strategies may include:
 - Hot Sites: Fully operational backup locations ready for immediate use, replicating the production environment. (For high-impact CBFs with short MTDs)
 - Warm Sites: Backup locations requiring some configuration before becoming operational. (For medium-impact CBFs with moderate MTDs)
 - Cold Sites: Offsite locations requiring significant setup time to resume operations. (For lower-impact CBFs with longer MTDs)
 - Cloud-based Recovery: Utilizing cloud platforms to restore data and applications.
- A comprehensive data backup and recovery plan has to be established to ensure the availability of critical data in the event of a disaster. This plan includes:
 - Regular backups of all critical data to secure offsite locations.
 - Data encryption to safeguard sensitive information.
 - Testing of backup and recovery procedures to ensure their effectiveness.
- A detailed incident response plan outlining the steps to be taken when a disruptive event occurs should be defined, including:
 - Activation of the BCP/DR team.
 - Communication protocols to notify stakeholders and coordinate recovery efforts.

- Procedures for isolating the incident, minimizing damage, and initiating recovery procedures.
- The BCP/DR plan should be tested regularly through simulations and exercises to ensure its effectiveness. The plan should also be reviewed and updated periodically to reflect changes in the NBFC's business environment, IT infrastructure, and regulatory requirements.
- Roles and Responsibilities of various stakeholders below:
 - Management: Provide leadership, resources, and oversight for the BCP/DR program.
 - BCP/DR Team: Responsible for developing, implementing, testing, and maintaining the BCP/DR plan.
 - IT Security Team: Plays a critical role in incident response, data recovery, and maintaining secure backup environments.
 - Business Unit Owners: Responsible for ensuring their respective business units can recover critical functions according to the plan.
- A clear communication plan should be established to ensure timely and accurate information is disseminated to stakeholders during a disruptive event. This includes communication protocols for employees, customers, regulators, and other relevant parties.
- This BCP/DR plan should be designed to align with the specific requirements outlined in the RBI IT Master Direction for NBFCs. This includes:
 - Maintaining documented BCP/DR policies and procedures.
 - Conducting periodic risk assessments and BIA.
 - Testing and exercising the BCP/DR plan on a regular basis.
 - Reporting BCP/DR testing results to the Board of Directors or Audit Committee (as mandated by RBI).

9. IT Outsourcing

- Before outsourcing any IT services, a thorough due diligence on potential service providers should be conducted. This due diligence should include:
 - Assessing the service provider's:
 - Financial stability and reputation.
 - Security policies and practices.
 - Regulatory compliance.
 - Experience in serving the financial services industry.
 - Obtaining references from the service provider's existing clients.
 - Evaluating the service provider's proposed service level agreements (SLAs) to ensure they meet the NBFC's specific requirements.
- All IT outsourcing arrangements should be formalized through written contracts that clearly define:
 - The scope of services being outsourced.
 - Security obligations of the service provider, including data security measures and incident response protocols.
 - Service level expectations and performance metrics.
 - Business continuity and disaster recovery plans of the service provider.
 - Audit rights of the NBFC to access the service provider's facilities and review their controls.
 - Termination clauses for non-compliance or security breaches.

- Appropriate data security measures should be implemented to protect sensitive information even in an outsourced environment. These measures may include:
 - Data encryption at rest and in transit.
 - Access controls to restrict access to data only for authorized personnel.
 - Regular security awareness training for employees who interact with outsourced services.
- The core functions that are critical to its daily operations and regulatory compliance should not be outsourced. These core functions may include:
 - Risk management
 - Customer relationship management
 - Regulatory reporting
- Any material IT outsourcing arrangements must be reported to the RBI as per the IT Master Direction's requirements.
- This IT Outsourcing Policy should be reviewed and updated periodically to reflect changes in:
 - The NBFC's business environment and IT needs.
 - Regulatory requirements of the RBI IT Master Direction.
 - Industry best practices for IT security and outsourcing.